

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA51 **COURSE NAME:** Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

Industry Problem-Solving Task

Code of Conduct:

I _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Annexure A
Industry Problem-Solving Task

1. A multinational enterprise is deploying IPsec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

- A. Identify which traffic requires AH, ESP, or both
 - B. Design packet flow with appropriate IPsec modes (transport/tunnel)
 - C. Justify protocol selection for different data types
 - D. Evaluate performance vs security trade-offs
2. An organization faces frequent key management issues in its IPsec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

- A. Analyze current SA lifecycle issues
 - B. Design an automated key management mechanism (e.g., IKE-based)
 - C. Propose a strategy for key renewal and revocation
 - D. Evaluate scalability and fault tolerance
3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

- A. Compare PGP and S/MIME in real-world deployment scenarios
 - B. Analyze key management and trust models
 - C. Recommend a solution with justification
 - D. Design a high-level implementation workflow
4. A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system

and propose an advanced spam detection strategy using email headers and content analysis.

Tasks:

- A. Identify limitations of existing filtering techniques
 - B. Analyze email headers for spoofing indicators
 - C. Design an improved detection model (rule-based or ML-based)
 - D. Evaluate effectiveness and false positive handling
5. During a security audit, it is found that encrypted email messages are vulnerable due to improper certificate handling in S/MIME. Diagnose the possible issues and recommend best practices to ensure secure certificate management and trust validation.

Tasks:

- A. Identify potential certificate-related vulnerabilities
- B. Analyze trust chain and validation process
- C. Propose secure certificate storage and management practices
- D. Recommend improvements for user awareness and system configuration

RUBRICS FOR CALCULATION:

Q. No	Understanding of Concepts (25)	Experimental Design (30)	Use of Tools (20)	Analysis of Results (15)	Documentation (10)	Total Score (out of 100)
1	/ 4	/ 4	/ 4	/ 4	/ 4	
2	/ 4	/ 4	/ 4	/ 4	/ 4	
3	/ 4	/ 4	/ 4	/ 4	/ 4	
4	/ 4	/ 4	/ 4	/ 4	/ 4	
5	/ 4	/ 4	/ 4	/ 4	/ 4	
OVERALL RUBRICS VALUE						
	/ 4	/ 4	/ 4	/ 4	/ 4	
	/ 25	/ 30	/ 20	/ 15	/ 10	/ 100

Cryptography CO4AT2:

R. Deepasri (192511309)

1. IPSec Deployment for Multinational Branch Offices

A. Identify which traffic requires AH, ESP, or both

Traffic type	Recommended	Reason
Normal business data	ESP	Provides confidentiality + integrity
Financial/transaction data	ESP with authentication	Sensitive data requires encryption and integrity
Voice/video traffic	ESP	Protects sensitive communication; can use optimized algorithms
Public/non-sensitive traffic	AH or no IPSec, depending on policy	Encryption may not be necessary
Highly sensitive inter-branch traffic	ESP	Encryption and authentication are both required

Recommendation: In modern deployments, **ESP is generally preferred over AH** because ESP can provide confidentiality, integrity, authentication, and anti-replay protection.

AH is useful when authentication/integrity is required without encryption, but it does not provide confidentiality.

B. Packet flow and IPSec modes

For communication between branch offices:

Branch A → Internet → Branch B

Tunnel mode:

Original IP Packet → ESP Tunnel → Internet → ESP Decapsulation → Original Packet

Tunnel mode protects the complete original IP packet and is therefore appropriate for **site-to-site VPNs**.

For communication between individual hosts:

Application Data → TCP/UDP → IP → ESP Transport → Network

Transport mode protects the payload while retaining the original IP header.

C. Protocol selection

- **ESP Tunnel Mode:** Best for branch-to-branch VPNs.
- **ESP Transport Mode:** Suitable for host-to-host protection.
- **AH:** Suitable where authentication/integrity is needed but encryption is not required.
- **ESP + authentication:** Preferred for confidential business information.

D. Performance vs security trade-off

Choice	Security Performance	
AH	Medium	High
ESP without encryption	Medium	High
ESP with encryption	High	Medium
ESP with strong encryption + authentication	Very high	Lower

Industry solution: Deploy **ESP tunnel mode for site-to-site VPNs**, using authenticated encryption such as **AES-GCM**, with hardware acceleration where available. This gives strong security while minimizing performance overhead.

2. IPsec Security Association and Key Management

A. Current SA lifecycle problems

Common enterprise problems include:

- Expired Security Associations
- Mismatched encryption parameters
- Manually configured keys
- Inconsistent policies between branches
- Failure to renew keys
- Stale SAs remaining after configuration changes
- Lack of centralized monitoring

These problems can cause VPN downtime and security weaknesses.

B. Automated IKE-based mechanism

Implement **IKEv2 (Internet Key Exchange version 2)**.

Basic workflow:

VPN Gateway A

↓

IKEv2 Authentication

↓

Security Parameters Negotiation

↓

Secure Key Establishment

↓

IPSec Child SA Creation

↓

Encrypted Communication

IKEv2 automatically negotiates cryptographic parameters and establishes keys instead of requiring administrators to manually configure every session key.

C. Key renewal and revocation

Use:

- Automatic SA lifetime management
- Automatic rekeying before expiration
- Short-lived session keys
- Centralized certificate management
- Immediate removal of compromised credentials
- Monitoring and alerting for failed negotiations

If a key or certificate is compromised, affected credentials should be revoked and new credentials issued.

D. Scalability and fault tolerance

For a multinational company:

- Deploy redundant VPN gateways.
- Use centralized configuration management.
- Maintain multiple IKE/IPSec gateways.
- Use automated monitoring.
- Store configuration securely.

- Use load balancing where appropriate.
- Use backup gateways for disaster recovery.

Industry solution:

Central Policy → IKEv2 → Automated SA Creation → Automatic Rekey → Monitoring → Failover

This removes much of the manual key-management burden and makes hundreds or thousands of VPN connections easier to maintain.

3. PGP vs S/MIME for Financial Email

A. Real-world comparison

Feature	PGP	S/MIME
Encryption	Yes	Yes
Digital signature	Yes	Yes
Trust model	Web of trust / decentralized Certificate/PKI based	
Enterprise management	More difficult	Easier
Corporate email integration	Variable	Strong
Certificate management	User-oriented	Centralized PKI possible
Large enterprise deployment	More complex	Generally preferable

B. Key management and trust

PGP

PGP commonly uses a decentralized trust model where users can verify and sign each other's public keys.

S/MIME

S/MIME uses digital certificates issued through a **Public Key Infrastructure (PKI)**.

Trust generally follows:

Root CA → Intermediate CA → User Certificate

The receiving system validates the certificate chain before trusting the sender's certificate.

C. Recommendation

For a **financial services company**, I would recommend **S/MIME** when the organization already has, or is willing to establish, enterprise PKI.

Reasons:

1. Better integration with enterprise email environments.
2. Centralized certificate management.
3. Easier policy enforcement.
4. Strong identity binding through certificates.
5. Easier integration with corporate directory systems.
6. Better suitability for large-scale organizational deployment.

PGP can still be appropriate for specialized users or organizations that prefer decentralized key management.

D. High-level implementation workflow

Employee Identity

↓

Certificate Authority

↓

S/MIME Certificate Issued

↓

Private Key Securely Stored

↓

Email Digitally Signed

↓

Email Encrypted

↓

Recipient Validates Certificate

↓

Signature Verification

↓

Message Decryption

Industry solution: Establish centralized PKI, automate certificate issuance/renewal, integrate it with corporate email systems, and provide users with clear certificate-status indicators.

4. Advanced Spam and Phishing Detection

A. Limitations of existing filtering

Basic spam filters commonly depend heavily on:

- Keyword matching
- Blocklists
- Simple sender reputation
- Static rules
- Known spam signatures

Attackers can bypass these techniques by modifying message content, using compromised accounts, or changing sending infrastructure.

B. Email-header spoofing indicators

Important header information includes:

- From
- Reply-To
- Return-Path
- Received
- Message-ID
- Authentication results

The system should check authentication mechanisms such as:

SPF

Determines whether the sending server is authorized for the domain.

DKIM

Checks whether the message was cryptographically signed by an authorized domain.

DMARC

Uses domain-alignment rules and SPF/DKIM results to determine whether a message should be accepted, quarantined, or rejected according to the domain's policy.

Suspicious indicators include:

From domain ≠ authenticated domain

Reply-To ≠ From

Unexpected sending server

Authentication failure

Suspicious routing path

C. Improved detection model

A hybrid system is preferable:

Email

↓

Header Analysis

↓

SPF/DKIM/DMARC Validation

↓

Sender Reputation

↓

Content Analysis

↓

URL/Attachment Analysis

↓

Machine Learning Classifier

↓

Risk Score

↓

Accept / Quarantine / Reject

A machine-learning model can analyze features such as:

- Sender reputation
- Header anomalies
- Message structure
- Language patterns
- URL characteristics
- Historical behavior
- Authentication results

D. Effectiveness and false positives

A good system should not simply classify everything suspicious as spam.

Use multiple actions:

Risk	Action
-------------	---------------

Very low	Deliver
----------	---------

Medium	Warning/quarantine
--------	--------------------

High	Quarantine
------	------------

Very high	Reject
-----------	--------

False positives can be reduced using:

- User feedback
- Allow lists for trusted systems
- Continuous model training
- Quarantine review
- Confidence thresholds

Industry solution: Use a **hybrid rule-based + ML-based email security gateway**, with SPF, DKIM and DMARC validation as the first layer and behavioral/content analysis as additional layers.

5. S/MIME Certificate Security Audit

A. Potential certificate vulnerabilities

Possible problems include:

- Expired certificates
- Revoked certificates still being trusted
- Incorrect certificate chain
- Untrusted Certificate Authority
- Weak or outdated cryptographic algorithms
- Private-key exposure
- Incorrect certificate-to-email identity mapping
- Poor certificate renewal procedures
- Failure to check certificate revocation
- Improper certificate storage

These problems can cause users to trust certificates that should no longer be trusted.

B. Trust-chain validation

The receiving system should validate:

User Certificate

↓

Intermediate CA

↓

Root CA

The system should verify:

1. Certificate validity period.
2. Certificate signature.
3. Certificate chain.
4. Intended usage/key usage.
5. Subject/SAN identity.
6. Revocation status.
7. Appropriate cryptographic algorithms.

If validation fails, the email client/security system should warn the user or prevent trust depending on organizational policy.

C. Secure certificate management

Recommended practices:

- Store private keys in protected key stores.
- Restrict access to private keys.
- Use enterprise PKI.
- Automate certificate renewal.
- Maintain certificate inventories.
- Monitor expiration dates.
- Immediately revoke compromised certificates.
- Maintain reliable CA backups.
- Use strong modern cryptographic algorithms.

- Separate administrative privileges.

D. User awareness and configuration

Employees should be trained to recognize:

- Invalid certificate warnings
- Expired certificate messages
- Untrusted certificate warnings
- Unexpected sender identities
- Signature verification failures

The organization should centrally configure email clients so users cannot easily bypass important certificate warnings.

Overall Industry Solution

The five problems can be combined into a **layered enterprise security architecture**:

Enterprise Network

→ **IPSec ESP + IKEv2**

Email Encryption

→ **S/MIME + Enterprise PKI**

Email Authentication

→ **SPF + DKIM + DMARC**

Threat Detection

→ **Rules + ML + Reputation Analysis**

Certificate Security

→ **Centralized PKI + Automated Renewal + Revocation**

This approach provides **confidentiality, integrity, authentication, secure key management, phishing protection, and scalable enterprise administration** while balancing security, performance, and operational cost.